Public Sources, Threat Reports and the Threat Catalogue

Cyberthreat newsletters, security advisories, CVE and MITRE ATT&CK · reading and rating a threat report · building Kalmia's threat catalogue

420-1C2-DW Threats and Risks · Class 5 · Thursday, November 5, 2026

AEC Cybersecurity: Prevention and Intervention (LEA.D8)

Topic 3 — Identifying Threats (Part 2) · Competency EZ02

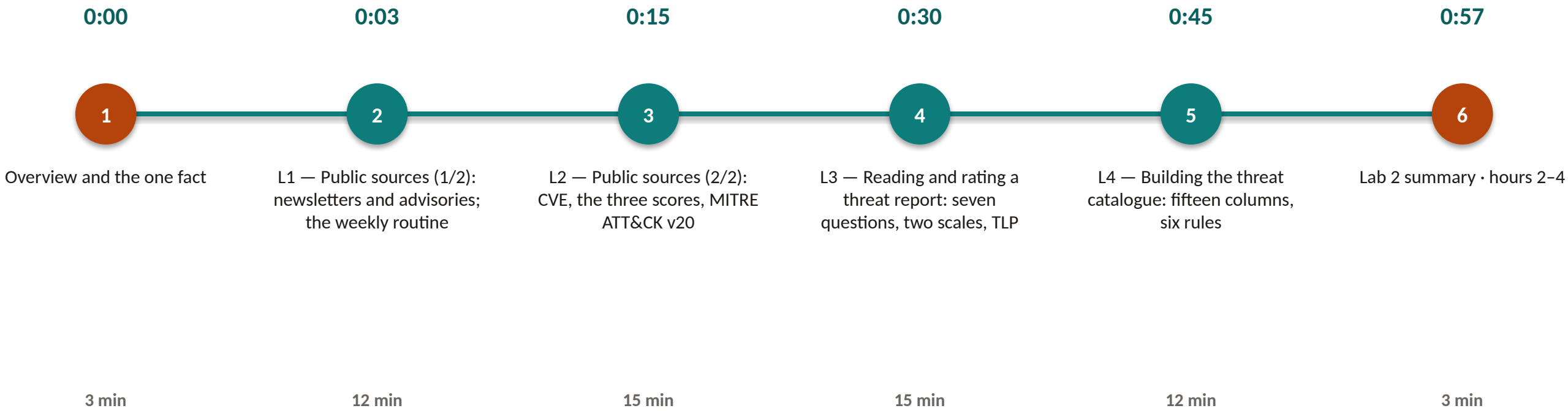
Hour 1 — lecture in four lessons (60 min) · Lab 1 due tonight · Lab 2 starts in hour 2

The one fact to remember

Public sources are read against your own inventory.

- Severity is a property of the flaw (CVSS).
- Relevance is a property of your organization (inventory, exposure facts).
- Evidence is what connects them (KEV, incidents, warning signs).
- Every row of the threat catalogue must carry all three.

The lecture hour — four lessons on the clock



Each lesson: read-aloud script → key terms → micro-activity → videos → real-life example → interactive code example → schematic → five flash-cards → formative quiz.

By the end of this hour you will be able to

- Name the six families of public threat-information sources, tell an alert from an advisory and from a newsletter, and run the four-step weekly watch routine against the Lab 1 inventory.
- Read a CVE record and an ATT&CK page; keep CVSS (severity), EPSS (probability) and KEV (evidence) apart; write a threat event with both identifiers.
- Apply the seven questions to any threat report; rate the source (A–F) and the information (1–6); respect TLP 2.0; use estimative language correctly.
- Build and check a threat catalogue in the fifteen-column format of Lab 2, with the relevance formula and the six quality rules.

Lab 1 due tonight · the legal and ethical frame

Lab 1 — Asset inventory and infrastructure map

- Due tonight, Thursday, November 5, 2026, 23:59 Eastern Time
- Lab drop box of Léa (Omnivox) — 5 % — individual
- Late: −10 % per day; not accepted after seven days
- Run the Lab 1 readiness checker before you upload
- Your inventory is the filter used in every example tonight

Legal Notice v2.0 — sections that apply tonight

- §7.3 — threat reports, CVE records and ATT&CK pages are studied as information only: no interaction with the infrastructure, addresses or people they describe
- §7.3 — attribution is reported as the publisher's assessment, never asserted as a fact
- §14 / Annex C — check every link on VirusTotal or Google Safe Browsing before opening it
- §18 — your own words, your sources cited
- Full text: cyber-soho.github.io/prevmon (Legal Notice)

1

Lesson 1 — Public information sources (1/2)

Cyberthreat newsletters and security advisories — who publishes threat information, what each publication contains, and the weekly watch routine of a small organization

0:03 – 0:15 · 12 minutes

Why an analyst reads public sources every week

31 %

of breaches started with the exploitation of a vulnerability — the first vector for the first time in 19 editions (Verizon DBIR 2026)

48 %

of breaches involved ransomware (DBIR 2026)

48 %

of breaches involved a third party (DBIR 2026)

- Competency EZ02, criterion 2.3: a methodical analysis of public information sources.
- A public source is any publication an organization can read without a contract: agency alerts, vendor advisories, vulnerability databases, newsletters, annual reports.
- Kalmia: the web shop runs WordPress + 23 plugins on PHP; on October 21, 2026 PHP published an emergency release and the Cyber Centre alert AL26-026 the same day. Did the host apply it? That question needs a name, a version and a date.

Six families of public sources (1/2)

1 National authorities

Cyber Centre alerts (AL26-nnn) and advisories (AV26-nnn), ITSAP/ITSM guidance, NCTA 2025-2026, Ransomware Threat Outlook 2025–2027; CISA advisories and the KEV catalogue. Primary.

2 Vendors

Microsoft Security Update Guide (second Tuesday — next: November 10, 2026), WordPress and plugin releases, PHP advisories, NAS / camera / POS / firewall vendors. The only authoritative statement of affected and fixed versions. Primary.

3 Vulnerability and technique databases

The CVE list (502 CNAs), the NVD, EPSS, the KEV catalogue, MITRE ATT&CK v20 — Lesson 2. Primary records, derived scores.

Six families of public sources (2/2)

4 CERTs, CSIRTs and ISACs

Incident-response teams of a country, a sector or a company, and sector sharing centres. MS-ISAC advisories (CIS) are a model of a clear advisory; FIRST publishes the CVSS, EPSS and TLP standards. Primary or relayed.

5 Newsletters and digests

SANS NewsBites (twice a week), SANS Internet Storm Center diaries and StormCast, agency e-mail subscriptions. A filtered view of the week with links to the primary documents. Secondary — never the basis of a decision.

6 Research and industry reports

Verizon DBIR 2026, Mandiant M-Trends 2026 (vishing = second initial vector), ENISA Threat Landscape. Frequencies of threat events — the input of the likelihood column in Lab 3. Secondary, statistical.

Alert, advisory, bulletin, newsletter — four words that are not synonyms

Word	Who publishes it	What it contains	Example
Alert (AL26-nnn)	Cyber Centre	An active threat or a critical vulnerability; detection and mitigation advice; updated as the situation changes	AL26-026 (PHP), AL26-028 (help-desk vishing)
Advisory (AV26-nnn)	Cyber Centre	A vendor released a security update: affected and fixed versions	Several every day
Security bulletin	The vendor	The vendor's own publication of the same facts	Microsoft Security Update Guide; WordPress release notes
Newsletter / digest	Secondary publisher	A periodic summary with comments and links to the originals	SANS NewsBites, ISC StormCast
IOC vs TTP	—	Indicator of compromise = observable artefact (address, hash); tactics, techniques and procedures = the behaviour behind it	Indicators change daily; behaviours slowly (ATT&CK)

The weekly watch routine of a small organization

1

Collect

Open the 8–12 sources of the register in the same order; 20 minutes a day, one hour on Friday.

2

Filter

Keep an item only if its product and version are in the Lab 1 inventory, or if it matches an exposure fact of Class 4.

3

Record

One line per kept item: date, source, item, asset, severity as published, action, owner, deadline.

4

Decide

Act now · add to the catalogue (Lesson 4) · watch — with the reasons on the same line.

Rule of the course (§7.3): reading an alert is information gathering; opening an address it lists or downloading a sample it mentions is interaction with malicious infrastructure.

Real-life example 1 — Kalmia's watch list, week of November 2, 2026

Item (publisher)	Match in the inventory?	Decision
AL26-026 — critical PHP vulnerabilities CVE-2026-109618 / -109619; fixed in 8.2.35 / 8.3.36 / 8.4.27 / 8.5.12; KEV Oct 26 (Cyber Centre)	Yes — web shop A-16 (PHP on the hosted VPS, version unknown)	Act now (host asked, Nov 6) + catalogue
AL26-028 — help-desk voice phishing campaign (Cyber Centre)	Yes — InfoNord help desk, Microsoft 365 A-17, MFA on 2 admin accounts only	Act now (call-back rule, staff notice) + catalogue
AL26-027 — Brotli CVE-2026-111497, CVSS 9.2, KEV Oct 27 (Cyber Centre)	Yes — browsers and the web server at the host	Act now (host) + catalogue
AL26-025 — BeyondTrust Remote Support CVE-2026-102764, KEV Oct 16 (Cyber Centre)	Unknown — which remote-support product do InfoNord and RoastTech use?	Watch · ask the suppliers (2 days)
Microsoft Security Update Guide — November 10 release (vendor)	Yes — 12 Windows 11 PCs, Microsoft 365	Watch until the release
Wordfence advisory — UpdraftPlus CVE-2026-10795, fixed 1.26.5 (vendor CNA)	To verify — is the plugin among the 23? (W-05)	Act now if installed + catalogue
POS cloud provider status page (vendor, fictional)	Yes — POS A-13	Watch
Free newsletter relaying a social-media post (secondary)	No product, no version	Discard (one line, rating F6)

Interactive example 1 — the weekly advisory filter (Bash)

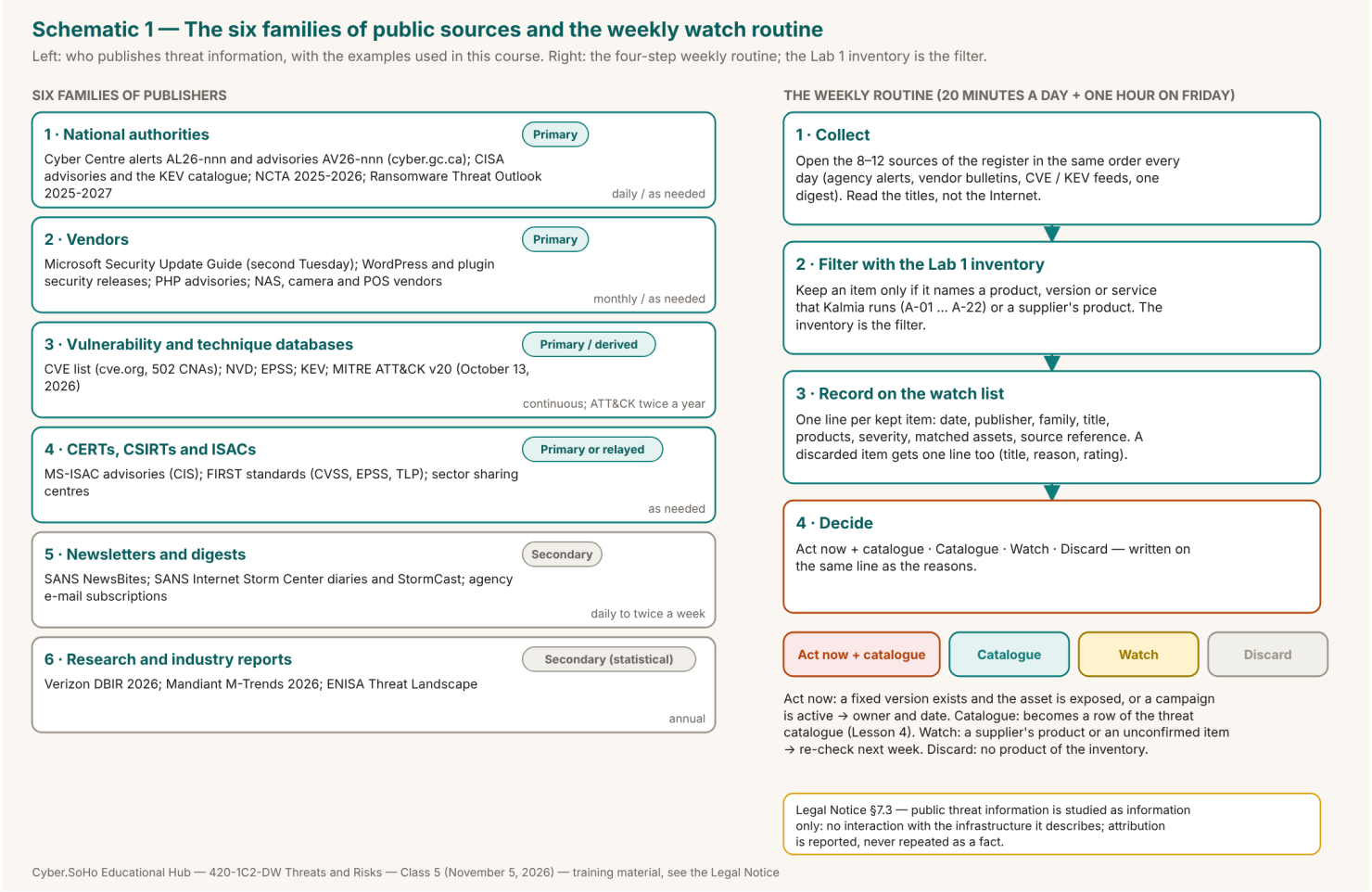
Bash · kalmia_advisory_watch.sh

- Reads advisories_week45.csv (8 items) and kalmia_keywords.csv (13 product keywords of the Lab 1 inventory)
- Keeps the items whose products match an asset; applies the decision rule
- Writes advisory_watchlist.csv — the Lab 2 watch-list format
- Replay in the module: Start / Pause · Step · Next event · Restart; the drawing sorts the eight items into the four decisions

Result of the recorded run: 8 items → act now 4 · watch 3 · discarded 1

Buttons in the module: Start / Pause · Step · Next event · Restart · speed · Copy code · download script, data, output, drawing, page.

Schematic 1 — The six families and the weekly routine



Left: the six families of publishers. Right: collect → filter (Lab 1 inventory) → record → decide. — downloadable as SVG / PNG from the module.

Lesson 1 — micro-activity, videos, flash-cards, quiz

Micro-activity

Micro-activity (5 min): the class sorts four new titles into keep / discard with the Kalmia inventory and names the family of each publisher.

Videos (≤ 15 min, confirmed working)

▶️ Professor Messer — Threat Research (SY0-601 1.5) · 7:34

▶️ Professor Messer — Threat Intelligence (SY0-701 4.3) · 4:46

(links and VirusTotal checks in the module)

Flash-cards and formative quiz

Five flash-cards, then 4 MCQ + 2 MSQ — formative, in the module.

The quiz does not count toward the mark; Quiz 2 (Friday) is separate.

2

Lesson 2 — Public information sources (2/2)

CVE and MITRE ATT&CK — one identifier for one vulnerability, one identifier for one attacker behaviour, and the three scores that say how urgent a vulnerability is

0:15 – 0:30 · 15 minutes

A CVE record — one identifier for one vulnerability

The program

- CVE-YYYY-NNNNN — the identifier never changes; everything else can be updated
- Run since 1999 by MITRE, sponsored by CISA; records written by 502 CNAs (March 31, 2026)
- 48,185 records in 2025 · ~15,000 per quarter in 2026 · > 340,000 in total
- The NVD (NIST) enriches first the KEV and critical-software records since April 15, 2026; the rest are 'Not Scheduled'

The fields of CVE-2026-109618

- CNA: php · state Published · published October 21, 2026
- Affected: PHP 8.2 / 8.3 / 8.4 / 8.5 — fixed in 8.2.35 / 8.3.36 / 8.4.27 / 8.5.12
- Problem type: CWE-416 (use after free)
- Metrics: CVSS v4.0 base 9.2 Critical, with its vector string
- ADP container (CISA): KEV added October 26, 2026, due October 29

Three scores that answer three different questions

CVSS — how severe is it?

FIRST. Base score 0.0–10.0 from a vector string (attack vector, complexity, privileges, user interaction, impact on C / I / A). Published by the CNA, sometimes by the NVD. Severity — not risk.

EPSS — how probable is exploitation soon?

FIRST. A probability 0–1 that the CVE is exploited in the next 30 days, recomputed daily from observed data, with a percentile.

KEV — is it exploited now?

CISA. Reliable evidence of exploitation in the wild + a clear remediation. About 1,700 entries against > 340,000 CVEs: small and urgent. BOD 26-04 (June 10, 2026) sets the deadlines.

CVSS bands and the four questions of BOD 26-04

CVSS qualitative bands

- None 0.0
- Low 0.1 – 3.9
- Medium 4.0 – 6.9
- High 7.0 – 8.9
- Critical 9.0 – 10.0
- The band ranks the flaw; the inventory decides whether it is your problem

BOD 26-04 — four variables, five tiers

- Is the asset publicly exposed? (Lab 1 flag)
- Is the CVE in the KEV catalogue?
- Is exploitation automatable? (vector AV:N and UI:N)
- Does it give full control? (high impact)
- KEV + full control, or exposed + automatable + full control → 3 days (compromise check when in KEV)
- Other KEV combinations, or exposed + automatable or full control → 14 days · other single yes → 60 days · all no → next upgrade
- Kalmia, CVE-2026-109618 on the web shop: four yes → 3 days + compromise check

MITRE ATT&CK Enterprise v20 — fifteen tactics (October 13, 2026)

TA0043 Reconnaissance	TA0042 Resource Development	**TA0001 Initial Access**	TA0002 Execution	TA0003 Persistence
TA0004 Privilege Escalation	TA0005 Stealth	TA0112 Defense Impairment	TA0006 Credential Access	TA0007 Discovery
TA0008 Lateral Movement	TA0009 Collection	TA0011 Command and Control	TA0010 Exfiltration	TA0040 Impact

- A knowledge base of observed attacker behaviours — free, updated twice a year; matrices Enterprise, Mobile, ICS.
- v20: 15 tactics · 227 techniques · 479 sub-techniques · 178 groups · 842 software · 57 campaigns · 44 mitigations · 703 detection strategies.
- New in v20: Defense Evasion split into Stealth (TA0005) and Defense Impairment (TA0112).

ATT&CK — tactic, technique, sub-technique, procedure

1

Tactic — TAxxxx

The goal at one stage: TA0001 Initial Access.

2

Technique — Txxxx

One way of reaching it: T1190 Exploit Public-Facing Application; T1566 Phishing.

3

Sub-technique — Txxxx.xxx

A more specific way: T1566.004 Spearphishing Voice — the help-desk call of AL26-028.

4

Procedure

What one group or software actually did, with its source report (G0046 FIN7, S0154 Cobalt Strike, C0xxx campaigns).

Linked objects: mitigations M1xxx (Lab 4), detection strategies and analytics, groups, software, campaigns. The Navigator colours the techniques an organization faces (Lab 2).

Why the two identifiers belong in the catalogue

Plain words vs identifiers

- 'An attacker takes over the web shop' — cannot be compared, linked or verified
- 'A cybercriminal exploits CVE-2026-109618 on A-16 through T1190' — can be
- CVE → vendor advisory with a fixed version (evidence)
- Technique → ATT&CK mitigations and detections (Lab 4) and the groups that use it (capability rating)

Kalmia's facts, mapped

- INC-02 fake banking details → T1657 Financial Theft (via T1566.002)
- INC-05 and W-04 → T1566 Phishing, T1078 Valid Accounts
- AL26-028 → T1566.004 Spearphishing Voice
- RoastLink unattended access → T1133 External Remote Services
- Backup always connected → T1486 Data Encrypted for Impact
- A CVE is a vulnerability, not a threat: it is evidence on a row whose event names a source, a technique and an asset

Real-life example 2 — five CVE records → Kalmia's exposure table

CVE (CNA, published)	Product · versions	CVSS · KEV	Kalmia asset · technique	BOD 26-04 decision
CVE-2026-109618 (php, Oct 21)	PHP 8.2–8.5 < 8.2.35 / 8.3.36 / 8.4.27 / 8.5.12	9.2 v4.0 · KEV Oct 26	A-16 web shop · T1190	3 days + compromise check (host)
CVE-2026-10795 (Wordfence, Jun 11)	UpdraftPlus ≤ 1.26.4 → 1.26.5 / 2.26.5	8.1 v3.1 (9.8 on the vendor page) · KEV no	A-16 plugin · T1190	3-day tier if installed (exposed, automatable, full control)
CVE-2026-102764 (BeyondTrust, Oct)	Remote Support — supplier product?	9.3 · KEV Oct 16	SUPPLIER? · T1133	Ask InfoNord / RoastTech (2 days)
CVE-2026-111497 (Google, Oct)	Brotli library — browsers, web server, PHP Windows builds	9.2 · KEV Oct 27	A-16 / A-08 · T1203	3 days + compromise check (host and PCs)
CVE-2026-56155 (Microsoft, Jul)	AD FS — not in Kalmia's inventory	7.8 · KEV Jul 14	no match	Discard

Interactive example 2 — from CVE records to the exposure table (PowerShell 7)

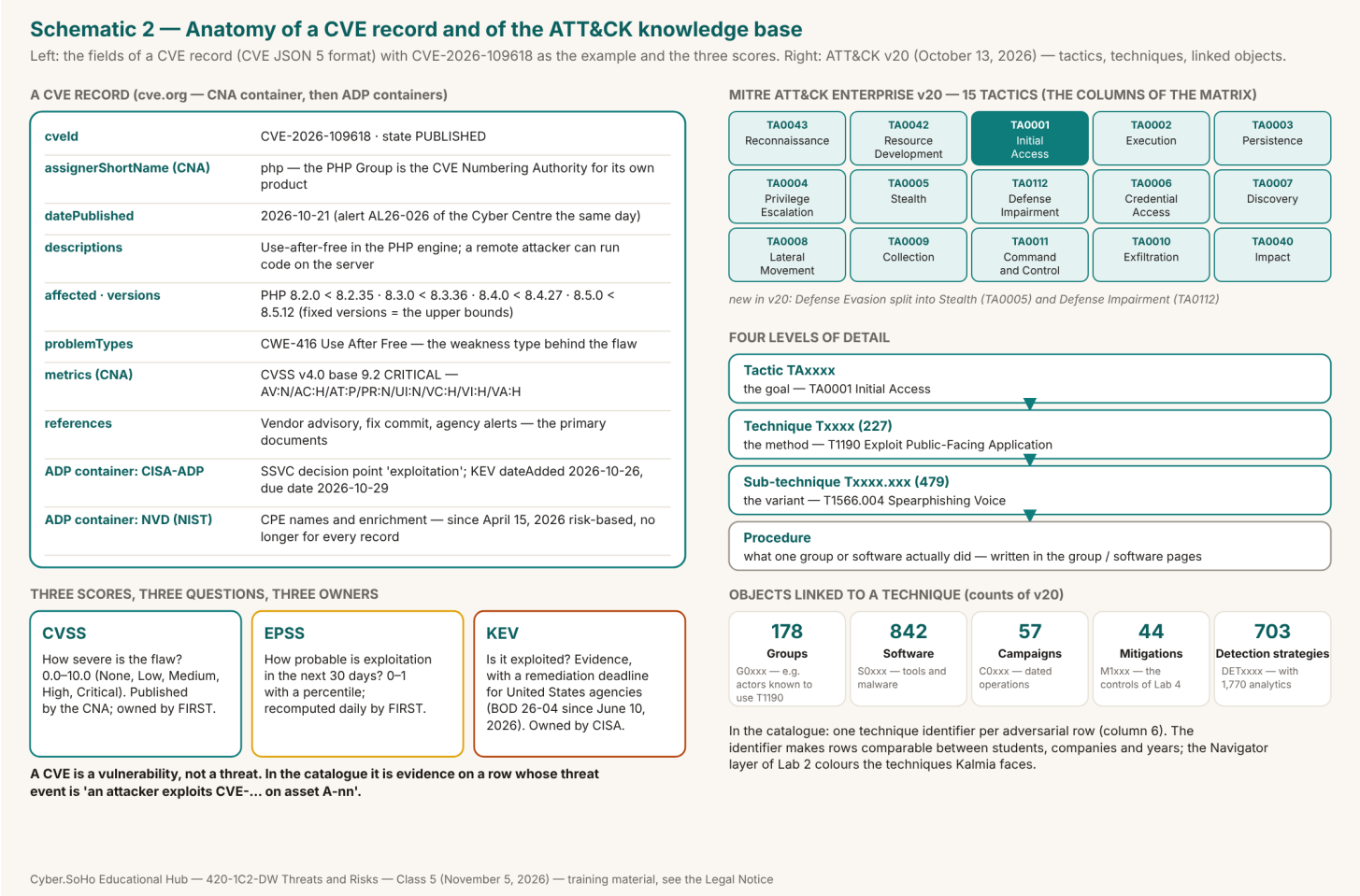
`PowerShell 7 · Get-KalmiaCveExposure.ps1`

- Reads five CVE records (JSON 5.1), kalmia_software.csv (10 lines) and technique_map.csv (CWE → ATT&CK technique)
- Reads CNA, product, versions, CWE, CVSS v4.0 / v3.1, KEV date from the CISA ADP container
- Matches the product against the inventory, maps the weakness to a technique, answers the four BOD 26-04 questions
- Writes cve_exposure.csv; the drawing places each record on the fifteen-tactic matrix and the CVSS scale

Result of the recorded run: 5 records · 4 matched · 4 in KEV · AD FS discarded

Buttons in the module: Start / Pause · Step · Next event · Restart · speed · Copy code · download script, data, output, drawing, page.

Schematic 2 — Anatomy of a CVE record and of ATT&CK



Left: the fields of CVE-2026-109618 and the three scores. Right: the fifteen tactics of v20, the four levels, the linked objects. — downloadable as SVG / PNG from the module.

Lesson 2 — micro-activity, videos, flash-cards, quiz

Micro-activity

Micro-activity (5 min): read the vector string CVSS:4.0/AV:N/AC:H/AT:P/PR:N/UI:N/VC:H/VI:H/VA:H metric by metric; then answer the four BOD 26-04 questions for Kalmia.

Videos (≤ 15 min, confirmed working)

▶️ Professor Messer — Analyzing Vulnerabilities (SY0-701 4.3) · 10:29

▶️ Red Hat — CVE and CVSS explained | Security Detail · 3:44

▶️ Tech with Gerard — MITRE ATT&CK Framework Explained in 4 Minutes

(links and VirusTotal checks in the module)

Flash-cards and formative quiz

Five flash-cards, then 4 MCQ + 2 MSQ — formative, in the module.

The quiz does not count toward the mark; Quiz 2 (Friday) is separate.

3

Lesson 3 — Methodical analysis of public sources

How to read and rate a threat report — seven questions in a fixed order, two six-level scales, the Cyber Centre's estimative language and TLP 2.0

0:30 – 0:45 · 15 minutes

Why a method, and not a reading

- A threat report is any document that describes a threat, a vulnerability, a campaign or an incident: alert, advisory, bulletin, research post, annual assessment.
- Two analysts who read the same report without a method reach different conclusions — and neither can explain why.
- Criterion 2.3 asks for a methodical analysis: the same questions, in the same order, with the answers written down, so that a colleague or the marker can check them.
- Seven questions: 1–3 about the document, 4–5 about the organization, 6–7 about the decision.
- NIST SP 800-150 (cyber threat information sharing) describes the same discipline: know the source, evaluate the quality, decide how it may be used.

The seven questions (1/2) — about the document

1

1 · Who publishes it, when, under which marking?

Publisher and family, date, update number, TLP marking. No date or no publisher → F6.

2

2 · What is it about?

Vulnerability (products, versions), campaign (technique, victims), actor, or incident — one sentence of your own.

3

3 · What is the evidence?

Observed (patch released, exploitation seen, infrastructure identified) versus assessed (probably, likely). Then rate the source A–F and the information 1–6.

Attribution to a group or a state is always an assessment: report who made it; never repeat it as a fact (Legal Notice §7.3).

The seven questions (2/2) — about us, and the decision

1

4 · Does it apply to us?

Products and versions against the Lab 1 inventory; the event against the exposure facts. Write the asset identifiers and the relevance (High / Moderate / Low / none).

2

5 · How does the threat act?

ATT&CK identifiers and the indicators the report gives — copied for the log search, never tested by visiting them.

3

6 · What is recommended, and can we do it?

Fixed versions, settings, notices, detection advice — with the owner at the organization or the supplier.

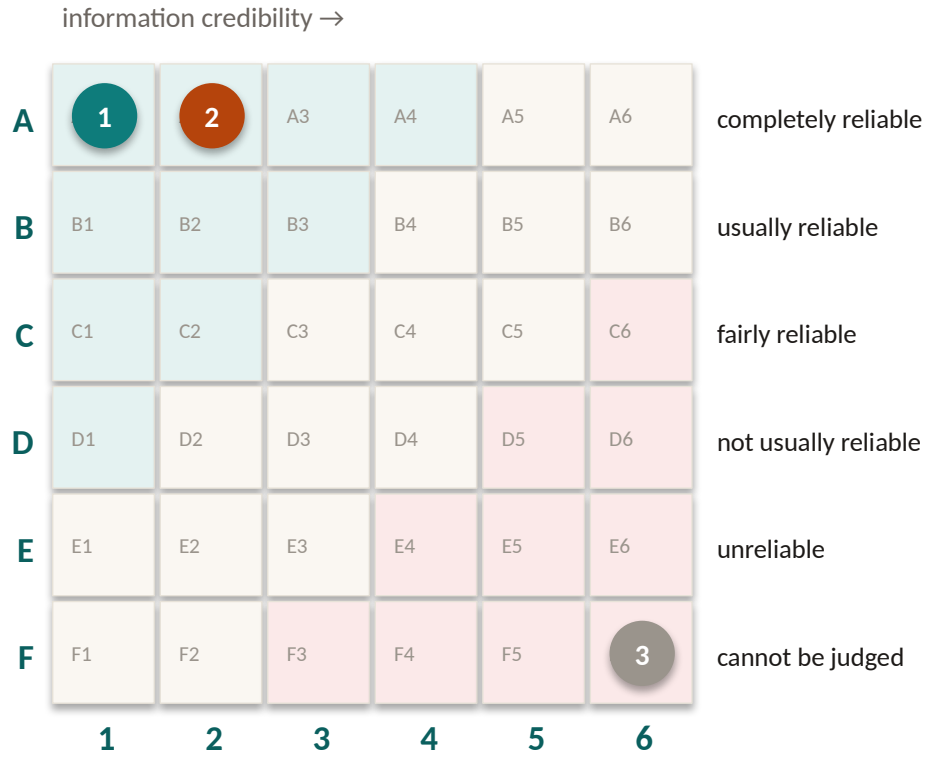
4

7 · What is our decision, and where is it recorded?

Act now · catalogue · watch · discard — ratings and reasons on the same line of the watch list.

A decision without its reasons cannot be reviewed.

Two scales for one report — source reliability × information credibility



1 confirmed by other sources · 2 probably true · 3 possibly true · 4 doubtful · 5 improbable · 6 cannot be judged

1. **A1 — AL26-026 — vendor and other agencies confirm**
2. **A2 — AL26-028 — consistent, not independently confirmed**
3. **F6 — anonymous post — nothing to evaluate**

- Admiralty / NATO system (AJP-2.1; US Army FM 2-22.3, Appendix B) — eighty years of use.
- Rated independently, written together: a usually reliable source can publish an unconfirmed item (B3); an unknown source can publish something others confirm (F1).
- OpenCTI stores both values on every report; Lab 2 stores them in column 15.

Estimative language and confidence — reading an assessment

The Cyber Centre's estimative words

- Almost no chance — 1–9 %
- Very unlikely — 10–24 %
- Unlikely — 25–39 %
- Roughly even chance — 40–59 %
- Likely — 60–74 %
- Very likely — 75–89 %
- Almost certainly — 90–99 %

How to read them

- Observed statements do not need these words; assessed statements do
- A confidence level (low / moderate / high) describes the quality of the sources and reasoning behind the judgment (ODNI ICD 203)
- 'The Cyber Centre assesses that exploitation is very likely' → write it as the publisher's assessment, with its date
- Lab 3 turns these words into the likelihood column

TLP 2.0 — what you may do with a report

TLP:RED	For the named recipients only — not even within their organization
TLP:AMBER+STRICT	Within the organization only
TLP:AMBER	Within the organization and with its clients, on a need-to-know basis
TLP:GREEN	Within the community (sector, peers); not published on the Internet
TLP:CLEAR	No limit on disclosure — public. Agency alerts and CVE records are TLP:CLEAR

- FIRST, version 2.0 since August 2022. The marking travels with the document and with every copy of it.
- Everything you read in this course is TLP:CLEAR; Lab 2 catalogues public material only.

Six errors the method prevents

Severity read as risk

A Critical score on a product you do not run is not your risk — question 4 before question 3.

CVSS copied into likelihood

CVSS is severity; likelihood comes from KEV, EPSS, exposure and intent.

Acting on a secondary source

The newsletter says 'critical'; the vendor bulletin says 'fixed in 1.26.5' — only the second tells you what to do.

Attribution repeated as fact

'The Cyber Centre assesses that…' is correct; 'group X attacked…' is not.

Date and update ignored

AL26-026 changed twice in six days; a decision taken on version 1 is re-read on version 3.

Indicator tested by visiting it

An address is copied for the log search; opening it is interaction with malicious infrastructure (§7.3).

Real-life example 3 — three documents rated for Kalmia

Question	AL26-026 — PHP (Cyber Centre)	AL26-028 — help-desk vishing (Cyber Centre)	'All WooCommerce stores hacked' (fictional post)
1 · Publisher, date, marking	National authority · Oct 21 (updates Oct 23 and 26) · public page, TLP:CLEAR	National authority · Oct 28 · TLP:CLEAR	Anonymous · undated · no marking
3 · Evidence → rating	Observed: fix, public PoC, exploitation in the wild + KEV Oct 26 (Update 2) → A1	Observed: infrastructure, techniques; assessed: sectors → A2	Nothing observed or referenced → F6
4 · Applies to Kalmia?	Yes — A-16 (PHP on the VPS, 25 % of revenue) → High	Yes — InfoNord help desk, MFA on 2 accounts, INC-05 → High	Cannot be matched → none
5 · ATT&CK	T1190	T1566.004 · T1621 · T1556	—
7 · Decision	Act now (host, Nov 6) + 2 catalogue rows	Act now (call-back rule, staff notice by Nov 9) + 2 rows	Discard — one line, F6

Interactive example 3 — threat report reader and rating grid (HTML / JavaScript)

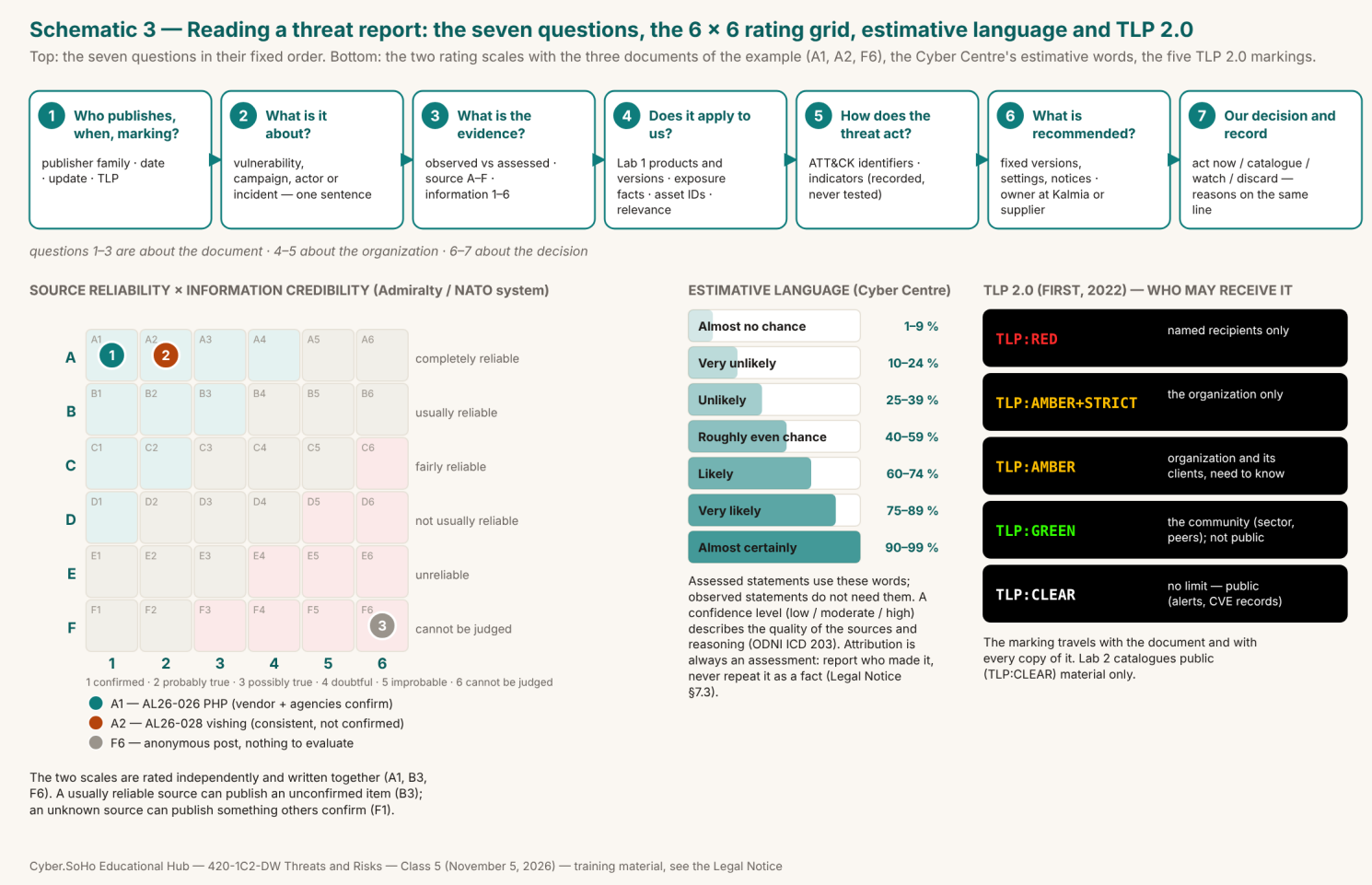
`Self-contained HTML · threat_report_rating_grid.html`

- Three documents as data: the two alerts summarized in the page's own words, and the fictional post
- Start walks through the seven questions; the passage that answers each one is highlighted in the document
- Question 3 places the marker on the 6 × 6 grid; question 4 sets the relevance; question 7 the decision
- Pause after any question to discuss; the ratings table is downloadable as CSV

Result: A1, A2 and F6 on one grid — two 'act now', one discard

Buttons in the module: Start / Pause · Step · Next event · Restart · speed · Copy code · download script, data, output, drawing, page.

Schematic 3 — Seven questions, the rating grid, estimative language, TLP 2.0



Top: the seven questions. Bottom: the 6 × 6 grid with A1, A2 and F6; the estimative scale; the five TLP markings. — downloadable as SVG / PNG from the module.

Lesson 3 — micro-activity, videos, flash-cards, quiz

Micro-activity

Micro-activity (5 min): a fourth document — the Wordfence advisory for CVE-2026-10795 (UpdraftPlus ≤ 1.26.4, fixed 1.26.5, CVSS 8.1 in the record, 9.8 on the vendor page). Seven answers in writing, two minutes, then compare.

Videos (≤ 15 min, confirmed working)

▶️ Professor Messer — Threat Intelligence (SY0-601 1.5) · 10:46

▶️ Adam Goss — Traffic Light Protocol explained · ~14 min

(links and VirusTotal checks in the module)

Flash-cards and formative quiz

Five flash-cards, then 4 MCQ + 2 MSQ — formative, in the module.

The quiz does not count toward the mark; Quiz 2 (Friday) is separate.

4

Lesson 4 — Building a threat catalogue for an organization

From the sources of Class 4 and the public items of tonight to the fifteen-column catalogue of Lab 2 — six steps, the relevance formula, six quality rules

0:45 – 0:57 · 12 minutes

What a threat catalogue is — and is not

It is

- The structured list of the threat sources and threat events relevant to the organization's assets
- Each row with the evidence that makes it relevant and the public reference that documents it
- The deliverable of Lab 2 — chapter 2 of the Integrative Project
- Method: NIST SP 800-30 r1 Tasks 2-1 and 2-2 (Appendix D sources, Appendix E events); ISO/IEC 27005:2022 Annex A as a checklist

It is not

- The risk register: no likelihood, no impact yet (Topic 5, Lab 3)
- A list of vulnerabilities (Topic 4)
- A list of tools: 'ransomware' is a tool, not an event
- A list of people: findings describe accounts and processes, never a culprit

How to write a threat event — one row, one sentence, four parts

source + action (technique) + asset + means or precondition

- A cybercriminal group encrypts NAS-01 (A-03) and the always-connected backup disk (A-04) after entering with a phished Microsoft 365 password — T1486. ✓ a threat event
- 'Ransomware' × — a tool.
- 'The NAS administrator password is shared by four people' × — a vulnerability (Topic 4); it goes in the evidence column of the event that uses it.
- Non-adversarial rows keep the same shape: the supplier's cloud POS service fails for a day (A-13) — structural; a flood reaches the roastery (A-01) — environmental.

The six steps

1

1 · Start from the assets and the exposure facts

Lab 1 inventory + the twelve facts F01–F12; every critical asset ends up in a row.

2

2 · List the sources

Four external profiles, three internal types, three non-adversarial families — twelve sources for Kalmia.

3

3 · Derive the events

Techniques per source (ATT&CK) × assets where they make sense; the week's public items are evidence, with their rating.

4

4 · Merge and split

Same source, technique, asset and entry point → one row with two pieces of evidence; two entry points → two rows.

5

5 · Rate

Capability, intent, targeting (1–5); facts matched; relevance by the formula.

6

6 · Check the quality

The six rules, before the file is handed in.

The fifteen columns of Lab 2 (1/2)

Identity of the event (columns 1–7)

- 1 Threat ID — T-01, T-02 …
- 2 Threat source — the Class 4 profile or the non-adversarial source
- 3 Source family (NIST) — Adversarial · Accidental · Structural · Environmental
- 4 External / internal / third party
- 5 Threat event — the four-part sentence
- 6 ATT&CK technique — Txxxx or Txxxx.xxx (new tonight)
- 7 Kalmia asset — A-nn from Lab 1

Why these first

- Columns 1–7 make the row unique and comparable
- Column 6 links the row to mitigations (Lab 4) and to the groups that use the technique
- Column 7 is checked against your Lab 1 file by the checker script
- A row without 5, 6 (adversarial) or 7 fails quality rule 2 (Specific)

The fifteen columns of Lab 2 (2/2) — ratings and evidence

Ratings (columns 8–12)

- 8 Capability (1–5) · 9 Intent (1–5) · 10 Targeting (1–5) — NIST SP 800-30 Appendix D; 1 for non-adversarial rows
- 11 Exposure facts matched — how many of F01–F12 the event relies on
- 12 Relevance — High if (Intent ≥ 4 and Capability ≥ 3) or facts ≥ 3; Moderate if Intent ≥ 3 or facts ≥ 2; otherwise Low

Evidence (columns 13–15)

- 13 Evidence — Kalmia documents: W-nn, INC-nn, Lab 1 findings, supplier answers
- 14 Source — the public reference with its date (alert, CVE record, assessment, standard)
- 15 Source rating — reliability A–F and credibility 1–6 (new tonight)
- The workbook computes column 12; the checker reads all fifteen in this order

Six quality rules

1 Complete

Every exposure fact, incident and critical asset appears in a row — or its absence is explained.

2 Specific

Source + technique (or mechanism) + asset identifier in every row. 'Hackers attack the company' fails.

3 Evidenced

Kalmia evidence and a dated, rated public reference on every row; otherwise delete or mark 'to verify'.

4 Threats, not vulnerabilities

A weakness goes in the evidence column of the event that uses it — never as a row.

5 Factual and ethical

No person named as a culprit; attribution reported as the publisher's assessment; fictional data only (§6.7, 7.3, 7.5, 18).

6 Consistent

Lab 1 identifiers, Class 4 source names, ATT&CK v20 techniques, fifteen columns in order — readable by the checker and the marker.

From the catalogue to the risk register — Labs 3 and 4

1

Lab 2 — threat catalogue (tonight → Nov 14)

Who or what, how, against which asset, with what evidence.

2

Topic 4 — vulnerabilities (Classes 6 and 9)

The weaknesses each event needs: scan reports, obsolete software, network architecture.

3

Lab 3 — risk register (Topic 5)

Per row: likelihood (intent, targeting, KEV, EPSS, incidents, exposure facts) × impact (Lab 1 business impact, CVSS impact metrics) = risk score; the register is the catalogue sorted by that score.

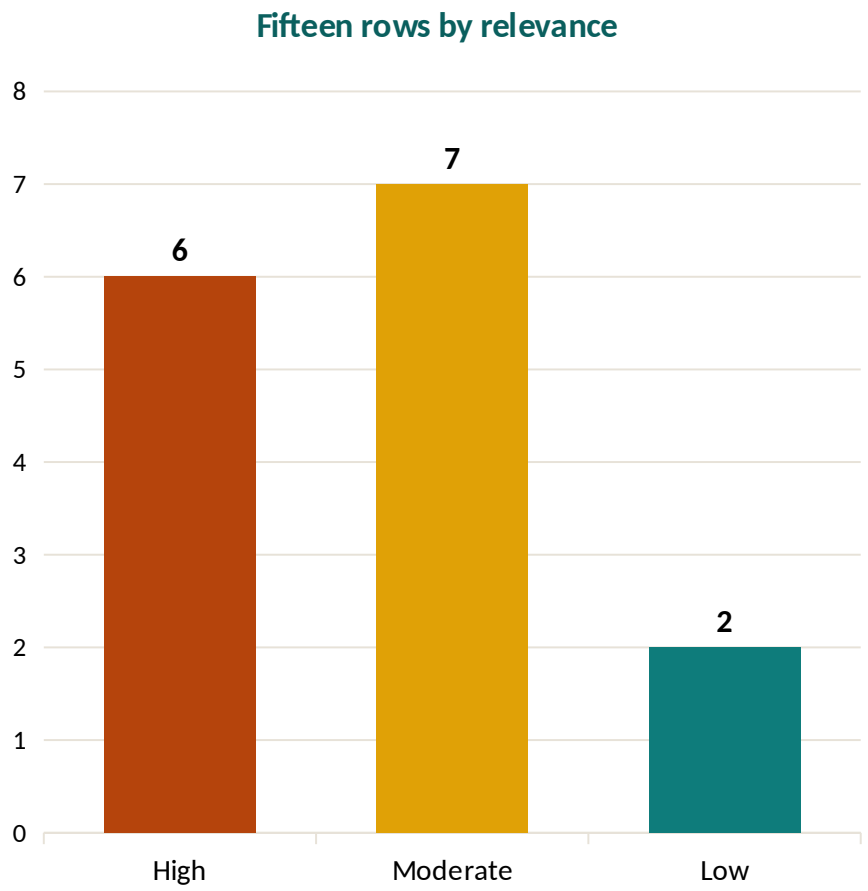
4

Lab 4 — controls

The ATT&CK identifiers pull the matching mitigations in one step.

Confidentiality: a finished catalogue tells an attacker which assets matter and which suppliers have access — it stays in the course folder and goes to the professor through Léa only (§7.5, §18.2).

Real-life example 4 — Kalmia's catalogue: fifteen rows from Classes 4 and 5



- Twelve sources (TS-01 … TS-12), sixteen events, fifteen rows after one merge (the two PHP CVEs are one event).
- High: ransomware on NAS-01 + backup (T1486), PHP exploitation (T1190), plugin exploitation (T1190), BEC fraud (T1657), vishing (T1566.004), payroll fraud (T1657).
- Moderate: camera scanning, hacktivist DDoS, insider with loyalty data (T1078), negligent user (T1566.002), POS supplier failure, RoastLink remote access (T1133), firewall exploitation.
- Low: state-sponsored router compromise; environmental event at the roastery.
- All six quality rules pass; the file is the Lab 2 seed.

Interactive example 4 — building the catalogue (Python 3)

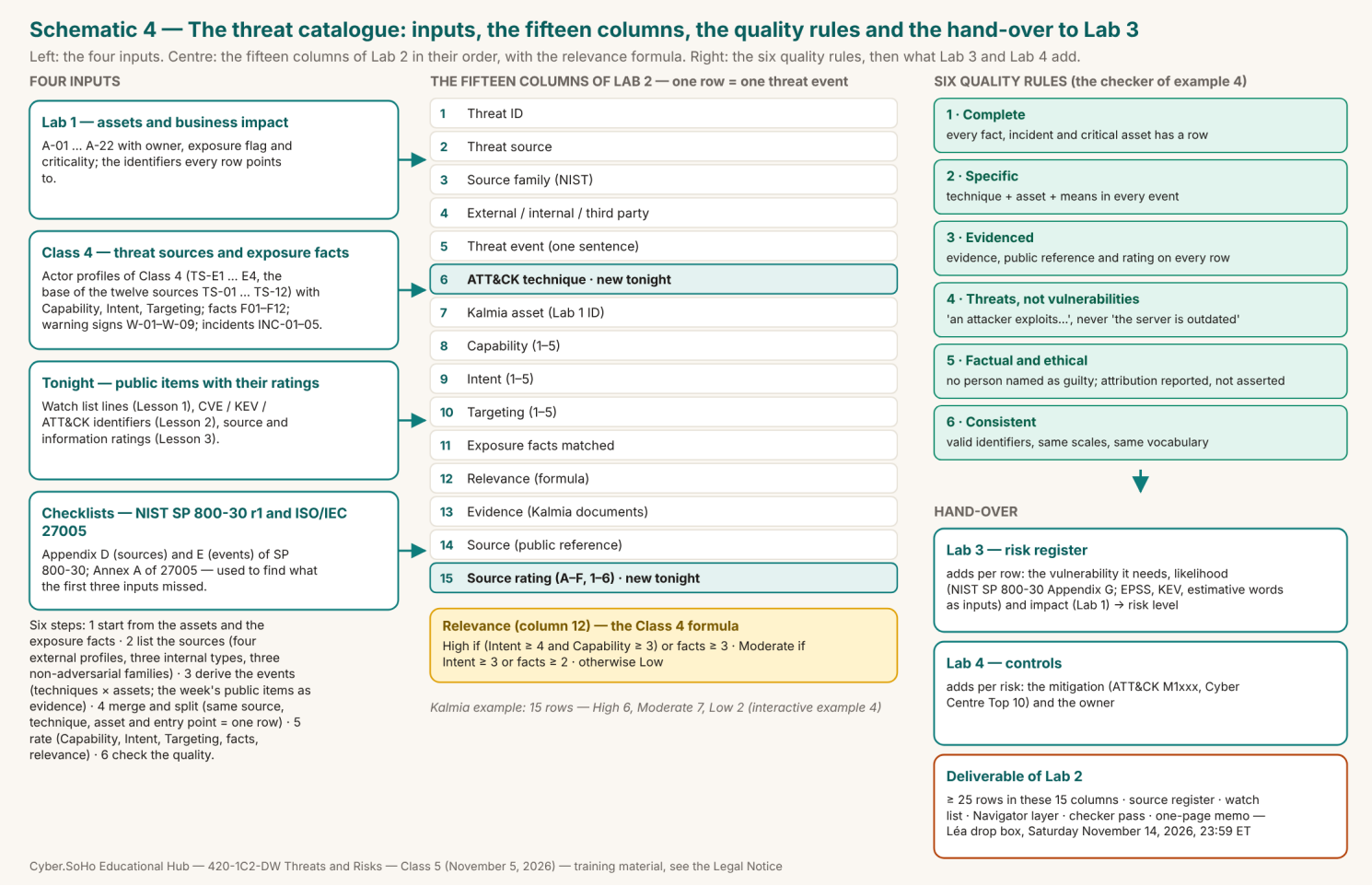
`Python 3 · kalmia_threat_catalogue.py`

- Joins threat_sources.csv (C · I · T scores), threat_events.csv, assets.csv, facts.csv and incidents.csv
- Computes the relevance with the Class 4 formula; merges duplicates (same source, technique, asset, entry point)
- Runs the six quality rules; writes the fifteen-column CSV of Lab 2
- --check mode validates a student's CSV (≥ 25 rows) — the checker report is part of the Lab 2 submission

Result of the recorded run: 15 rows · High 6 · Moderate 7 · Low 2 · six rules PASS

Buttons in the module: Start / Pause · Step · Next event · Restart · speed · Copy code · download script, data, output, drawing, page.

Schematic 4 — The threat catalogue: inputs, fifteen columns, quality rules, hand-over



Left: the four inputs. Centre: the fifteen columns and the relevance formula. Right: the six rules and what Labs 3 and 4 add. — downloadable as SVG / PNG from the module.

Lesson 4 — micro-activity, videos, flash-cards, quiz

Micro-activity

Micro-activity (5 min): each student writes one new row for Kalmia in the four-part form, with its technique and asset identifier; two rows are read aloud and checked against the six rules.

Videos (≤ 15 min, confirmed working)

▶️ Professor Messer — Risk Analysis (SY0-701 5.2) · 9:13

▶️ BioTech Whisperer — Threat Modelling Explained Simply · 3 min

(links and VirusTotal checks in the module)

Flash-cards and formative quiz

Five flash-cards, then 4 MCQ + 2 MSQ — formative, in the module.

The quiz does not count toward the mark; Quiz 2 (Friday) is separate.

Lab 2 — Threat catalogue (Integrative Project, Part 2) — summary

- Deliverable: Kalmia's catalogue in the Lab 2 workbook — at least 25 rows in the fifteen columns (the fifteen seed rows may be kept and must be completed).
- Coverage: all Class 4 actor profiles and insider types, the three non-adversarial families, INC-01 to INC-05, F01–F12, every critical asset.
- Public sources: a source register of 8–12 sources and a watch list of at least 8 items read between October 15 and November 13, 2026, each with the seven answers in short form.
- ATT&CK map: the techniques of the adversarial rows in the ATT&CK Navigator (Enterprise v20), exported as an image, with a half-page note.
- Checker: the CSV export passes kalmia_threat_catalogue.py --check with zero rule errors; the report is included.
- Memo: one page to Nadia Roy — the five High rows in plain language, their evidence, the three open supplier questions.
- Due Saturday, November 14, 2026, 23:59 Eastern Time — Léa drop box, one ZIP — 5 % — individual. The full instruction sheet, quick guide and visual guide are provided separately.

Hours 2–4 tonight · next classes

Tonight after the lecture

- Hour 2 (7:05–8:00): Lab 1 last checks and upload before 23:59; Lab 2 opened — starter workbook, seed rows, source register template
- Hour 3 (8:10–9:00): workshop in pairs — two public items of the week rated with the seven questions, catalogue rows written, ratings reviewed on screen
- Hour 4 (9:10–9:55): ATT&CK Navigator walk-through, checker run on the seed file, open supplier questions

Next classes

- Class 6 — Friday, November 6, 6–10 pm, online: Topic 4 (Part 1), network architecture, obsolete software, reading a scan report; Quiz 2 (Topics 1–4)
- Class 7 — Saturday, November 7, 2–6 pm, online: midterm review of Topics 1–4
- Class 8 — Monday, November 9, 6–10 pm, IN CLASS: midterm exam (25 %), Topics 1–4
- Class 11 — Saturday, November 14: Lab 2 due 23:59 ET; Lab 3 starts

Key references (official sites — check each link on VirusTotal before opening it)

- Canadian Centre for Cyber Security — Alerts and advisories · NCTA 2025-2026 · Ransomware Threat Outlook 2025–2027 — cyber.gc.ca
- CISA — Known Exploited Vulnerabilities catalogue · BOD 26-04 — cisa.gov
- CVE Program — cve.org · NVD — nvd.nist.gov · FIRST — CVSS v4.0, EPSS, TLP 2.0 — first.org
- MITRE ATT&CK v20 and the ATT&CK Navigator — attack.mitre.org
- NIST SP 800-30 r1 (risk assessment) · SP 800-150 (threat information sharing) — csrc.nist.gov
- Verizon DBIR 2026 · Mandiant M-Trends 2026 · ENISA Threat Landscape · SANS NewsBites and Internet Storm Center
- Cyber.SoHo Legal Notice, Terms of Use and Acceptable Use Policy (v2.0) — cyber-soho.github.io/prevmon
- The complete list with explanations and VirusTotal links is in the module's Links section.

Legal and ethical notice — read before any lab

Educational material — Cyber.SoHo / Asen Grozdanov. © 2026 Cyber.SoHo. All rights reserved. For use in an isolated, authorized lab environment only, against the targets this exercise designates. Applying these tools or techniques to any other system, network or data without the owner's express written authorization may be a criminal offence (Criminal Code, ss. 342.1, 342.2, 430(1.1) and 184) and is strictly prohibited. You alone are responsible for your actions and your equipment. Full terms: Cyber.SoHo Legal Notice, Terms of Use and Acceptable Use Policy, v2.0, section 7.

- Course rule (§7.3): threat reports, CVE records and ATT&CK pages are studied as information only — no interaction with live malicious infrastructure, threat actors or breach data; attribution is reported, never repeated as a fact.
- Link safety (§14, Annex C): every address is checked on VirusTotal or Google Safe Browsing before it is opened.
- Academic integrity (§18): your own words, your sources cited, no generated text handed in as yours.
- Statutes cited in §8: Criminal Code of Canada ss. 342.1, 342.2, 430(1.1), 184 · 18 U.S.C. §1030 · Directive 2013/40/EU · Ley Orgánica 10/1995.

Full terms: https://cyber-soho.github.io/prevmon/00.01.%20cyber.soho%20-%20legal.html



Thank you — see you in hour 2

Ten-minute break.

Hour 2: Lab 1 upload before 23:59 · Lab 2 opens with the fifteen seed rows.

Severity · relevance · evidence — every row carries all three.